

Tableau de Bord RGPD — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
DPO : Sophie Blanc
Statut : Validé
Référence : Règlement UE 2016/679 (RGPD) — Articles 5, 13, 30, 32, 33, 35, 46

Contexte RGPD TechShop SAS

Pourquoi TechShop est pleinement soumise au RGPD

Critère	Situation TechShop	Implication
Établissement UE	Siège à Toulouse, France	RGPD s'applique (Art. 3.1)
Données personnelles traitées	~15 000 clients + 47 salariés	Registre des traitements obligatoire (Art. 30)
Traitement à grande échelle ?	Non (< 100 000 personnes)	AIPD non systématiquement obligatoire
DPO obligatoire ?	Non (PME non publique, pas de traitement à grande échelle)	DPO désigné volontairement — bonne pratique
Transferts hors UE	Oui (AWS us-east-1, PayPal US, HubSpot US)	Garanties Art. 46 requises

Les 5 grands principes RGPD appliqués à TechShop

Art. 5 ? Principes fondamentaux
??
? 1. Lic?it?, loyaut?, transparence -> Base l?gale + mentions ?
? 2. Limitation des finalit?s -> Pas de r?utilisation ?
? 3. Minimisation des donn?es -> Collecter le minimum ?
? 4. Exactitude -> Donn?es ? jour ?
? 5. Limitation de la conservation -> Dur?es d?finies ?
? 6. Int?grit? et confidentialit? -> S?curit? (Art. 32) ?
? 7. Responsabilit? (accountability) -> Prouver la conformit? ?
??

Registre des Traitements (Article 30)

Le registre des traitements est **obligatoire** pour toute organisation de plus de 250 salariés, et **recommandé fortement** pour les PME traitant des données sensibles ou à grande échelle. TechShop SAS maintient ce registre volontairement, conformément à la bonne pratique CNIL.

Traitement T01 — Gestion des clients et des commandes

Champ	Détail
Référence	T01
Nom du traitement	Gestion de la relation client et traitement des commandes e-commerce
Finalité	Traitement des commandes en ligne, livraison, facturation, service après-vente, historique d'achats
Base légale	Contrat (Art. 6.1.b) — exécution du contrat de vente
Responsable de traitement	TechShop SAS — Marie Laurent (DG)
Catégories de personnes	Clients particuliers (B2C) et professionnels (B2B revendeurs)
Catégories de données	Nom, prénom, email, adresse postale, numéro de téléphone, historique commandes, adresse IP
Données sensibles	Non (aucune donnée Art. 9 RGPD)
Nombre de personnes concernées	~15 000 clients actifs
Destinataires	Transporteurs (Colissimo, DPD), Stripe (paiement), OVH (hébergement), Google (Workspace)
Transferts hors UE	[!] Stripe (USA — PCI-DSS + SCC), PayPal (USA — SCC)
Durée de conservation	Données client actif : durée de la relation + 3 ans (prospection) / Données comptables : 10 ans (obligation légale)
Mesures de sécurité	TLS 1.3, authentification, backups chiffrés S3, logs d'accès, Cloudflare WAF
Conformité	[OK] Base légale claire / [!] Transferts hors UE à documenter (SCC Stripe)

Traitement T02 — Marketing et communication commerciale

Champ	Détail
Référence	T02
Nom du traitement	Marketing direct, newsletters, offres promotionnelles
Finalité	Envoi d'emails commerciaux, promotions, relances panier abandonné, fidélisation

Champ	Détail
Base légale	Consentement (Art. 6.1.a) — opt-in explicite lors de l'inscription + Intérêt légitime (Art. 6.1.f) pour les clients existants (soft opt-in)
Responsable de traitement	TechShop SAS — Responsable marketing
Catégories de personnes	Clients ayant consenti + abonnés newsletter
Catégories de données	Email, prénom, historique d'achats, comportement de navigation (cookies), préférences
Données sensibles	Non
Nombre de personnes concernées	~8 000 abonnés newsletter actifs
Destinataires	HubSpot (CRM/emailing), Google Analytics
Transferts hors UE	[!] HubSpot (USA) — DPA disponible uniquement à partir de HubSpot Starter (payant)
Durée de conservation	Jusqu'à désinscription + 3 ans / Cookies : 13 mois maximum (CNIL)
Mesures de sécurité	Accès restreint HubSpot, lien désabonnement dans chaque email, registre des consentements
Conformité	[!] Non-conformité identifiée : HubSpot Free sans DPA -> transfert hors UE non garanti

Traitement T03 — Gestion des ressources humaines

Champ	Détail
Référence	T03
Nom du traitement	Gestion administrative du personnel
Finalité	Paie, contrats de travail, congés, formation, évaluation, obligations sociales et fiscales
Base légale	Obligation légale (Art. 6.1.c) — Code du travail, obligations URSSAF, DSN
Responsable de traitement	TechShop SAS — DRH
Catégories de personnes	47 salariés + anciens salariés
Catégories de données	Nom, prénom, NIR (numéro sécu), RIB, contrat, salaire, évaluations, absences, formation
Données sensibles	[!] NIR = donnée à caractère personnel particulière (Art. 87 Loi Informatique et Libertés)
Nombre de personnes concernées	47 salariés actifs + ~20 anciens salariés
Destinataires	Expert-comptable, URSSAF, mutuelle, organisme de formation
Transferts hors UE	Aucun (Odoo HR auto-hébergé OVH France)
Durée de conservation	Bulletin de paie : 50 ans (prescription prud'homale) / Contrat : 5 ans après départ / CV candidats non retenus : 2 ans

Champ	Détail
Mesures de sécurité	Accès Odoo HR restreint DRH uniquement, chiffrement backups, Google Workspace chiffré
Conformité	[OK] Base légale solide / [!] Accès Odoo HR à auditer (RBAC) — R12

Traitement T04 — Analytics et mesure d'audience

Champ	Détail
Référence	T04
Nom du traitement	Mesure d'audience du site e-commerce, analyse comportementale visiteurs
Finalité	Amélioration de l'expérience utilisateur, optimisation des conversions, mesure des campagnes marketing
Base légale	Consentement (Art. 6.1.a) — bandeau cookies + Intérêt légitime pour analytics agrégés anonymes
Responsable de traitement	TechShop SAS — DSI + Responsable marketing
Catégories de personnes	Visiteurs du site (anonymes + identifiés si connectés)
Catégories de données	Adresse IP (pseudonymisée), pages visitées, durée de session, origine du trafic, device
Données sensibles	Non
Nombre de personnes concernées	~50 000 visiteurs uniques/mois
Destinataires	Google Analytics (Universal Analytics -> GA4), Grafana (interne)
Transferts hors UE	[!] Google Analytics (USA) — DPA Google disponible, mais transfert résiduel post-Schrems II à documenter
Durée de conservation	Données brutes : 14 mois (paramètre GA4) / Agrégats : illimité
Mesures de sécurité	IP anonymisée dans GA4, bandeau cookies CNIL conforme, opt-out disponible
Conformité	[!] Bandeau cookies à auditer (conformité CNIL 2021) / Envisager Matomo self-hosted (alternative privacy-first)

Traitement T05 — Gestion des fournisseurs et partenaires

Champ	Détail
Référence	T05
Nom du traitement	Gestion des contacts fournisseurs, partenaires, prestataires
Finalité	Gestion contractuelle, facturation fournisseurs, communication commerciale B2B

Champ	Détail
Base légale	Intérêt légitime (Art. 6.1.f) — gestion de la relation commerciale B2B
Responsable de traitement	TechShop SAS — Direction
Catégories de personnes	Contacts professionnels fournisseurs et partenaires
Catégories de données	Nom, prénom, email professionnel, téléphone, fonction, entreprise
Données sensibles	Non
Nombre de personnes concernées	~200 contacts
Destinataires	Google Workspace (stockage), Odoo (CRM fournisseurs)
Transferts hors UE	Google Workspace (USA) — DPA Google signé, SCC en place
Durée de conservation	Durée de la relation + 5 ans
Mesures de sécurité	Accès restreint, Google Workspace chiffré
Conformité	[OK] Conforme — base légale adaptée au B2B

Transferts hors UE — Analyse détaillée (Article 46)

Contexte juridique : Depuis l'arrêt Schrems II (CJUE, juillet 2020), le Privacy Shield USA-UE est invalidé. Les transferts vers les USA nécessitent des **Clauses Contractuelles Types (SCC)** adoptées par la Commission européenne (décision 2021/914) ou le nouveau **Data Privacy Framework (DPF, adopté juillet 2023)**.

Cartographie des transferts hors UE

Destinataire	Pays	Données transférées	Mécanisme légal	État	Action
Stripe	USA	Données de paiement (tokenisées)	PCI-DSS + SCC + DPF	[!] Partiel	Vérifier adhésion Stripe au DPF + signer DPA
PayPal	USA	Données de paiement	SCC + DPF	[!] Partiel	Documenter les SCC dans le registre
Google Workspace	USA	Emails, documents, contacts RH	SCC + DPF (Google certifié)	[OK] Conforme	DPA Google signé — vérifier annuellement
Google Analytics	USA	IP pseudonymisée, comportement	SCC + DPF	[!] Partiel	IP anonymisation activée + documenter
HubSpot	USA	Données prospects, comportement	[NON] Aucun (Free plan)	[NON] Non conforme	Passer HubSpot Starter OU migrer vers CRM EU

Destinataire	Pays	Données transférées	Mécanisme légal	État	Action
AWS S3 us-east-1	USA	Sauvegardes complètes (données clients + RH)	[NON] Aucun documenté	[NON] Non conforme	Migrer vers eu-west-3 — URGENT (M02)
AWS S3 eu-west-3	France	Sauvegardes principales	UE — pas de transfert	[OK] Conforme	RAS

Priorités de remédiation transferts hors UE

CRITIQUE ? ? corriger avant 31/07/2026

-> AWS S3 us-east-1 : données clients + RH sans garantie RGPD

Action : Migration eu-west-3 (Mesure M02 du PTR)

?LEV? ? ? corriger avant 30/09/2026

-> HubSpot Free : 8 000 prospects sans DPA

Action : Upgrade HubSpot Starter (50€/mois) OU migration Brevo (EU)

MOYEN ? ? documenter avant 31/12/2026

-> Stripe DPF : vérifier certification + signer DPA explicite

-> Google Analytics : documenter IP anonymisation dans le registre

Droits des personnes — État de mise en œuvre (Articles 15-22)

Droit	Article	Canal TechShop	Délai légal	État
Droit d'accès	15	Email DPO : dpo@techshop.fr	1 mois	[!] Partiel
Droit de rectification	16	Email DPO + espace client	1 mois	[!] Partiel
Droit à l'effacement	17	Email DPO	1 mois	[!] Partiel
Droit à la limitation	18	Email DPO	1 mois	[NON] Non formalisé
Droit à la portabilité	20	Export CSV disponible WooCommerce	1 mois	[!] Partiel
Droit d'opposition	21	Lien désabonnement + email DPO	Immédiat	[OK] Marketing
Droit de ne pas faire l'objet d'une décision automatisée	22	N/A (pas de profilage automatisé)	N/A	[OK] N/A

Action requise : Créer une page "Exercer mes droits" sur le site TechShop avec formulaire dédié et procédure interne de traitement des demandes (délai de réponse 1 mois max).

Gestion des violations de données (Article 33-34)

Procédure de notification CNIL (72 heures)

H+0 -> Détection de l'incident ?

H+4 -> Qualification : s'agit-il d'une violation de données personnelles ?
Critère : accès, divulgation, altération ou perte de données personnelles ?

H+24 -> Notification interne : DSI -> DPO -> DG
Ouverture registre des incidents (poc/cnil/registre-incident-001.md)

H+48 -> Évaluation du risque pour les personnes concernées
Risque FAIBLE -> Pas de notification CNIL obligatoire (documenter quand même)
Risque ?LEV? -> Notification CNIL obligatoire (Art. 33)
Risque TR?S ?LEV? -> Notification CNIL + notification aux personnes (Art. 34)

H+72 -> Notification CNIL via notifications.cnil.fr (si risque ?lev?)
Contenu obligatoire : nature violation, catégories/nombre personnes, conséquences probables, mesures prises

Preuve existante : poc/cnil/ contient le template de notification et un exercice de simulation (incident fictif R001 — fuite BDD clients WooCommerce).

Registre des violations (Art. 33.5)

ID	Date	Type	Données concernées	Personnes	Notification CNIL	Clôture
INC-001	Exercice juin 2026	Accès non autorisé BDD	Clients (emails, adresses)	~500	Simulée	Exercice
(aucun incident réel à ce jour)						

Non-conformités identifiées et plan de correction

Tableau de bord des écarts RGPD

ID	Non-conformité	Article RGPD	Risque	Priorité	Action	Échéance
NC-01	AWS S3 us-east-1 sans garantie de transfert	Art. 46	[CRITIQUE] Critique	URGENT	Migration eu-west-3 (M02)	31/07/2026
NC-02	HubSpot Free sans DPA	Art. 28, 46	[ELEVÉ] Élevé	Haute	Upgrade Starter OU migration Brevo	30/09/2026

ID	Non-conformité	Article RGPD	Risque	Priorité	Action	Échéance
NC-03	Bandeau cookies non audité (conformité CNIL 2021)	Art. 6, ePrivacy	[ELEVÉ] Élevé	Haute	Audit + mise en conformité Axe ptio/Tarteaucitr on	30/09/2026
NC-04	Mentions légales RGPD incomplètes sur le site	Art. 13	[MODERE] Modéré	Moyenne	Mise à jour politique de confidentialité	31/10/2026
NC-05	Aucune procédure formelle droits des personnes	Art. 15-22	[MODERE] Modéré	Moyenne	Création page + procédure interne	31/10/2026
NC-06	Durées de conservation non documentées pour tous les traitements	Art. 5.1.e	[MODERE] Modéré	Moyenne	Compléter registre des traitements	31/12/2026
NC-07	Accès Odo HR non restreint (données RH accessibles trop largement)	Art. 5.1.f, 32	[MODERE] Modéré	Moyenne	Reconfiguration RBAC Odo (R12)	30/09/2026
NC-08	Pas d'AIPD pour le traitement T04 (analytics à grande échelle)	Art. 35	[OK] Faible	Basse	Évaluer si AIPD nécessaire (50K visiteurs/mois)	31/03/2027

Score de conformité RGPD

Traitements conformes : 2/5 (T03, T05) -> 40%
 Traitements partiellement conf.: 3/5 (T01, T02, T04) -> 60%
 Transferts hors UE conformes : 2/7 (GW, AWS eu-w3) -> 29%
 Non-conformités critiques : 2 (NC-01, NC-02)
 Non-conformités totales : 8

Score global estimé : 52/100

Priorité absolue : NC-01 (AWS us-east-1) est le seul point qui expose TechShop à une amende CNIL immédiate en cas de contrôle. Correction estimée à **1 journée de travail DSI**. Le ratio effort/risque est le meilleur du plan de conformité.

Synthèse pour le CODIR

Indicateur	Valeur	Tendance
Traitements documentés	5/5	[OK] Complet
Transferts hors UE conformes	2/7	[CRITIQUE] À corriger
Non-conformités critiques	2	[CRITIQUE] Action immédiate
Droits des personnes opérationnels	3/7	[MODERE] En cours
Incidents RGPD (réels)	0	[OK]
DPO désigné	Oui (Sophie Blanc)	[OK]
Registre des traitements	En place	[OK]

Message à la direction : TechShop SAS a les fondations RGPD en place (registre, DPO, base légale). Les 2 non-conformités critiques sont correctives et peu coûteuses (migration S3 : 1 jour, HubSpot upgrade : 50€/mois). Sans action sous 60 jours, un contrôle CNIL suite à plainte client exposerait TechShop à une amende pouvant dépasser le coût de correction de plusieurs centaines de fois.

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026 — Mise à jour annuelle obligatoire Art. 30 RGPD